

Report – Esercizio W9D4

Regola Firewall pfSense (Blocco DVWA)

Corso: Cybersecurity & Ethical Hacking – Epicode

Studente: Cerasoli Giovanni Pio

Modulo: D4 – Penetration Testing

Ambiente: UTM (QEMU) su macOS

1. Obiettivo

Configurare una regola firewall su pfSense che blocchi l'accesso alla web app DVWA (in esecuzione su Metasploitable) da parte di Kali Linux, mantenendo le due macchine su sottoreti diverse e instradate attraverso pfSense.

2. Architettura di rete

Host	Interfaccia	IP	Note
pfSense	WAN	10.2.0.15	verso Internet
pfSense	LAN	192.168.50.1	rete Kali/Windows
pfSense	LAN2 (OPT1)	192.168.51.1	rete Metasploitable
Kali Linux	eth0	192.168.50.100 /24	gateway 192.168.50.1
Windows	–	192.168.50.102 /24	gateway 192.168.50.1
Metasploitable	eth0	192.168.51.101 /24	gateway 192.168.51.1

Kali e Metasploitable si trovano su sottoreti diverse (LAN vs LAN2): ogni pacchetto tra le due macchine deve obbligatoriamente attraversare pfSense, che può quindi filtrarlo con una regola firewall.

In UTM, ogni VM è collegata in modalità Solo Host a una specifica "rete host" (equivalente della "Rete interna" di VirtualBox):

- Kali → rete host Default (private), agganciata alla scheda LAN di pfSense
- Metasploitable → rete host LAB-LAN, agganciata alla scheda LAN2 di pfSense
- pfSense → una scheda di rete per ciascuna delle due reti host, più la WAN

W9D4 - Pratica PDF
Esercizio PfSense

EPICODE
Esercizio

Architettura esercizio

Ambiente Virtuale

EPICODE
Esercizio

Fig. 1 – Schema architettura ufficiale dell'esercizio (materiale del corso)

3. Problemi riscontrati durante la configurazione

Il troubleshooting ha richiesto diversi passaggi, in ordine:

1. VM in "Rete Condivisa" invece di "Host Only"

Sia Kali che Metasploitable erano inizialmente configurate in UTM con Network Mode "Rete Condivisa" (NAT/Shared). In questa modalità le VM comunicano direttamente tramite lo stack di rete di macOS, bypassando completamente pfSense: qualunque regola firewall creata risultava inefficace, perché il traffico non passava mai attraverso il router.

→ *Fix: entrambe le VM riportate su Network Mode Solo Host.*

2. Regola firewall con IP non corrispondenti

La prima regola creata usava gli IP di esempio della soluzione fornita dal corso (Source 192.168.1.100, Destination 192.168.50.100), diversi dagli IP reali assegnati alle VM nel lab. La regola quindi non veniva mai applicata.

→ *Fix: Source e Destination aggiornati con gli IP reali (verificati con "ip a" su entrambe le macchine).*

3. Interfaccia LAN di pfSense in modalità sbagliata

La scheda 2 di pfSense (destinata a LAN) era anch'essa su "Rete Condivisa" invece di "Solo Host", per cui era esposta sullo stesso bridge condiviso di macOS a cui si agganciava Kali quando era ancora in modalità condivisa.

→ *Fix: scheda LAN di pfSense impostata su Solo Host.*

4. Disallineamento tra reti host

Dopo il fix precedente, Kali era stata ricollegata alla rete host LAB-LAN, che in realtà era la rete destinata a LAN2/Metasploitable, non a LAN. Le due VM restavano quindi isolate tra loro pur essendo entrambe "Solo Host".

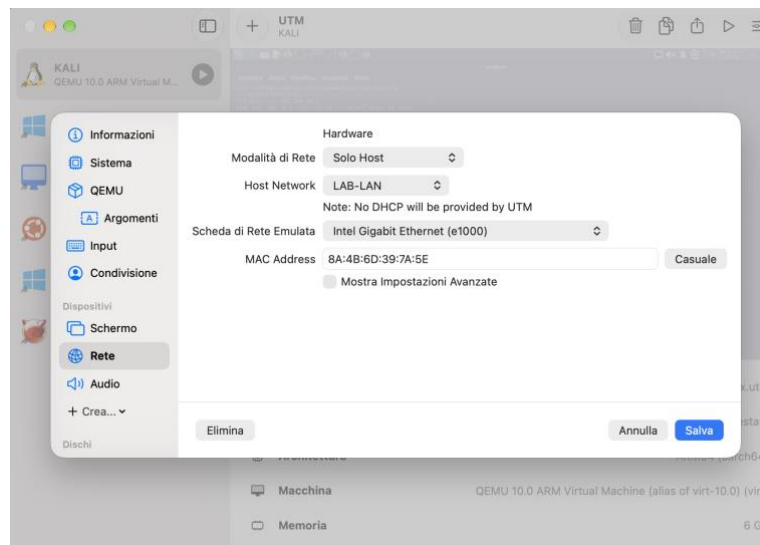


Fig. 2 – Kali erroneamente collegata alla rete host "LAB-LAN" (destinata invece a LAN2/Metasploitable)

Per individuare la rete corretta sono state confrontate le due schede "Solo Host" di pfSense tramite il rispettivo MAC address:

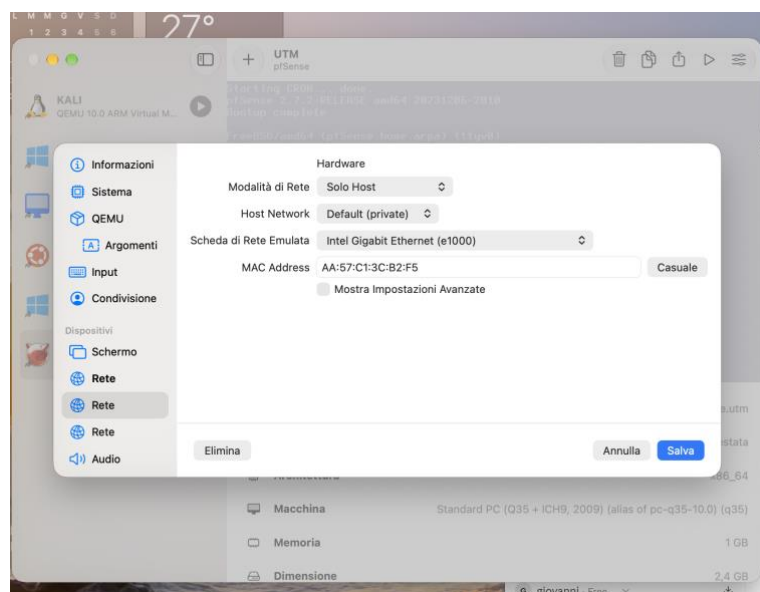


Fig. 3 – Scheda LAN di pfSense → rete host "Default (private)"

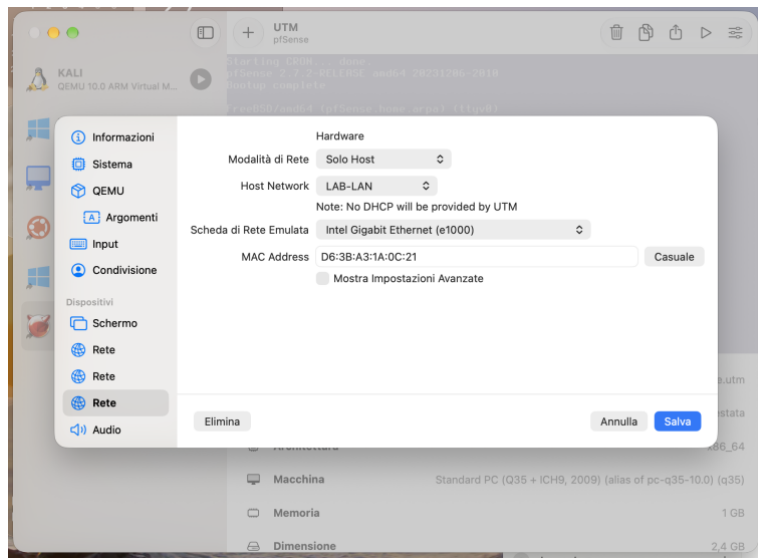


Fig. 4 – Scheda LAN2 di pfSense → rete host "LAB-LAN"

→ Fix: Kali riassegnata alla rete host Default (private), la stessa della scheda LAN di pfSense.

5. Metasploitable sulla sottorete sbagliata

Poiché inizialmente tutto il traffico passava sulla stessa rete condivisa, Metasploitable aveva ricevuto un IP nella sottorete 192.168.50.0/24 (stessa di Kali) invece che 192.168.51.0/24 (LAN2), rendendo l'isolamento nullo anche a livello IP.

→ Fix: IP di Metasploitable riconfigurato su 192.168.51.101/24, gateway 192.168.51.1.

4. Regola firewall finale

Su pfSense → Firewall → Rules → LAN:

Campo	Valore
Action	Block
Interface	LAN
Protocol	TCP
Source	192.168.50.100 (Kali)
Destination	192.168.51.101 (Metasploitable)
Destination Port	HTTP (80)
Log	Abilitato

La regola blocca solo il traffico TCP sulla porta 80; il traffico ICMP (ping) resta volutamente permesso.

Firewall / Rules / Edit

Edit Firewall Rule

Action Block
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface LAN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol TCP
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match Address or Alias 192.168.50.100 /
Display Advanced
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match Address or Alias 192.168.51.101 /
Destination Port Range HTTP (80) From Custom To Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Fig. 6 – Regola firewall configurata su pfSense (Firewall → Rules → Edit)

5. Verifica finale

- ping 192.168.51.101 da Kali → funzionante (ICMP non è filtrato dalla regola).
- Richiesta HTTP verso 192.168.51.101 da Kali → cattura Wireshark mostra ripetute retransmissioni del pacchetto SYN, senza alcun SYN-ACK né RST in risposta: comportamento coerente con un'azione Block (scarto silenzioso del pacchetto).
- Da confermare/consigliato: controllo su pfSense → Status → System Logs → Firewall (filtro interfaccia LAN) per verificare la presenza della riga di blocco corrispondente al tentativo.

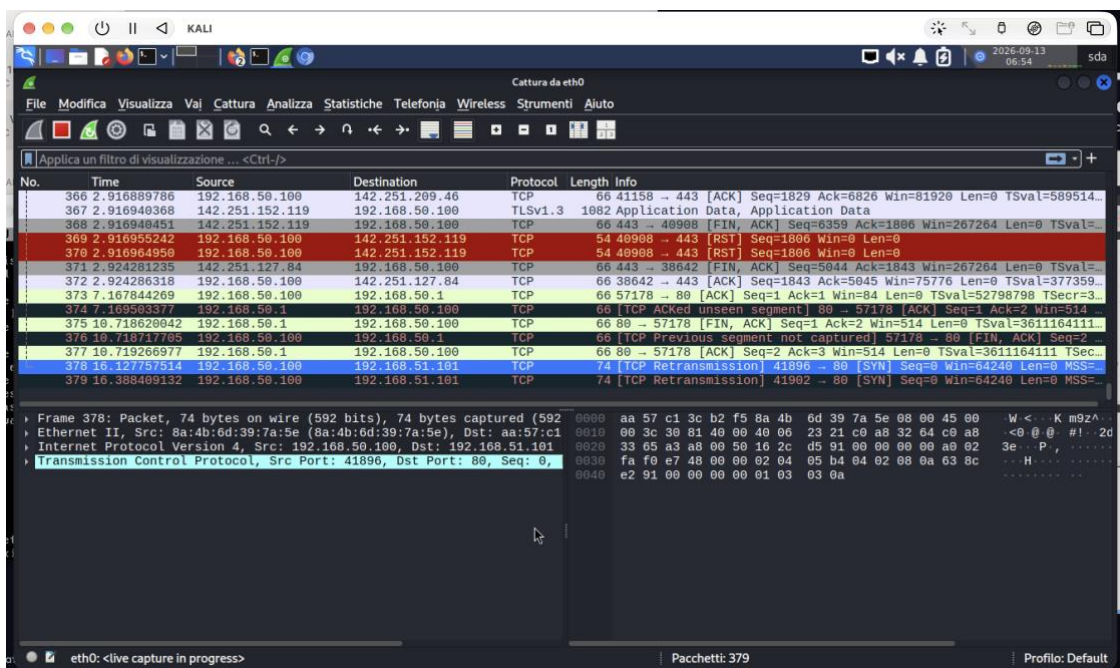


Fig. 5 – Cattura Wireshark su eth0 di Kali: pacchetti SYN in retrasmisione verso 192.168.51.101:80, nessuna risposta da Metasploitable

6. Conclusioni

L'esercizio è completato: pfSense instrada correttamente il traffico tra le due sottoreti (LAN e LAN2) e la regola firewall blocca in modo selettivo l'accesso HTTP a DVWA da Kali, lasciando invece passare il traffico ICMP. La causa principale dei problemi incontrati non era la sintassi della regola firewall in sé, ma un disallineamento a livello di rete virtuale in UTM (modalità di rete e reti host non corrispondenti tra le VM coinvolte), che impediva al traffico di passare fisicamente attraverso pfSense.